AWS SAA（SAA-C03）　分野1 セキュアなアーキテクチャの設計　#04

暗号化と秘密情報

鍵は KMS、専用の HSM は CloudHSM、証明書は ACM、パスワードは Secrets Manager。保存時と転送中を分けて考える

各ページの下に、根拠にした AWS の公式ドキュメント（KMS・CloudHSM・ACM・Secrets Manager・Parameter Store・S3・EBS・RDS）を書いた（青い文字を押すと開く）。「」の中はドキュメントの原文どおり（日本語版は機械翻訳のため、語順が不自然なところもそのまま）。会社名や構成の例は Claude が作った例

全体像 試験ガイド タスク 1.3

1 鍵を管理する
KMS のキーの種類・キーポリシー・グラント・エンベロープ暗号化・ローテーション・削除・マルチリージョンキー

2 鍵・証明書・秘密を置く場所
CloudHSM（専用 HSM）・ACM（SSL/TLS 証明書）・Secrets Manager と Parameter Store

3 保存時の暗号化
S3（SSE-S3・SSE-KMS・DSSE-KMS・SSE-C・クライアント側）・EBS・RDS

4 転送中の暗号化
TLS。S3 は aws:SecureTransport で HTTPS を強制。RDS は SSL/TLS で接続

タスク 1.3 の知識・スキル（要約）	このPDF
暗号化と適切なキー管理／暗号化キーにアクセスポリシーを実装する	**第1章**
保管中のデータを暗号化する（KMS など）	**第1・3章**
転送中のデータを暗号化する（TLS を使った ACM など）	**第2・3章**
データのバックアップとレプリケーション	**第1・3章（暗号化したまま複製。バックアップの仕組みは #10）**
データの保持と分類・データアクセスとガバナンス	**#05（Macie）・#13（S3）**

2つの軸：「保存時（at rest）」は KMS などの鍵で、「転送中（in transit）」は TLS の証明書で守る。問題文がどちらを聞いているかを先に見る。

出典：AWS「コンテンツ分野 1: セキュアなアーキテクチャの設計」タスク 1.3

第1章

KMS のキー

鍵そのものは KMS の外に出ない。データはデータキーで、データキーは KMS キーで封をする。

KMS キーの3つの種類

	カスタマーマネージドキー	AWS マネージドキー	AWS 所有のキー
だれが作る	自分	AWS のサービスが自分のアカウントに（aws/s3 など）	AWS のサービス（自分のアカウントの外）
キーポリシー	自分で決める	サービスが決める。見るだけ	見えない
ローテーション	選べる（自動・オンデマンド）	毎年自動。変えられない	サービスが決める
削除	予定を入れられる	できない	できない
CloudTrail で監査	できる	できる	できない
料金	月額＋使った分	月額なし・使った分	なし

選び方：キーを「監査も制御もしなくてよい」→ AWS 所有のキー。「監査はしたいが管理は任せたい」→ AWS マネージドキー。「権限・ローテーション・削除を自分で」「アカウント間で共有」→ カスタマーマネージドキー。

KMS キーはリージョンごと：別のリージョンで使うには、そのリージョンのキーを指定する（またはマルチリージョンキー）。

出典：AWS KMS keys（比較表・「すべての AWS マネージドキー は毎年自動的にローテーションされます。このローテーションスケジュールは変更できません。」）／Amazon RDS リソースの暗号化（「KMS キーは、作成された AWS リージョンに固有です。」）

エンベロープ暗号化



なぜ封筒にする：大きなデータを毎回 KMS に送らずにすむ。KMS には小さなデータキーの暗号化・復号だけを頼む。S3・EBS・RDS の暗号化もこの考え方。

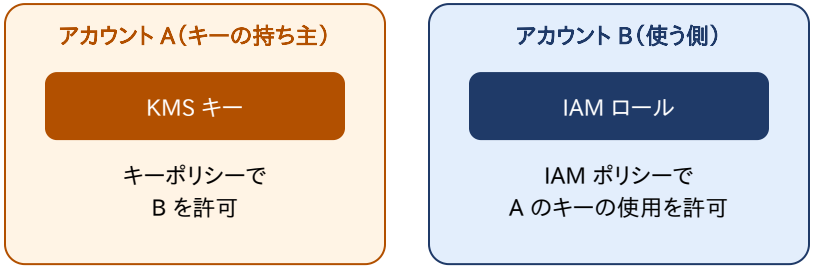
KMS はデータキーを保存しない：暗号化データキーはデータと一緒に自分で保存する。KMS キーそのものはダウンロードできない。

出典：AWS KMS 暗号化の必須事項（「データキーでプレーンテキストデータを暗号化してから、そのデータキーを別のキーで暗号化する手法です。」）／データキーを生成する（「ダウンロードできない対称 KMS キーとは異なり、データキーは AWS KMSの外部での使用のためにユーザーに返されます。」）

だれがキーを使えるか：キーポリシー・IAM・グラント

しくみ	役割
キーポリシー	KMS キーのリソースポリシー。すべてのキーにちょうど1つ必要。アクセス制御の主な方法
IAM ポリシー	デフォルトのキーポリシーが、キーを持つアカウントに IAM ポリシーでの許可を認めている
グラント	ポリシーを変えずに作って消せる一時的な許可。AWS のサービスが代わりにキーを使うときに多い。拒否はできない

別のアカウントにキーを使わせる

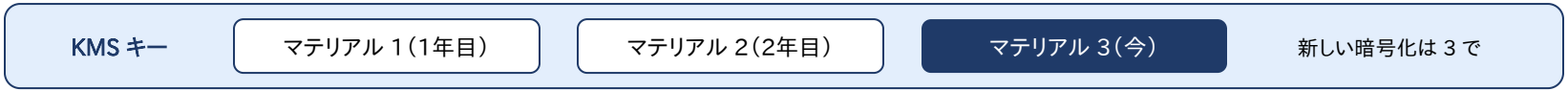


両方が要る：キーポリシー（持ち主側）と、相手のアカウントの IAM ポリシー。片方だけでは使えない。図は Claude が作った模式図。

出典：AWS KMS のキーポリシー（「すべての KMS キーには、厳密に 1 つのキーポリシーが必要です。」）／AWS KMS の許可（「グラントは KMS キーへのアクセスを許可できますが、アクセスを拒否することはできません。」）／他のアカウントのユーザーに KMS キーの使用を許可する（「クロスアカウントアクセスには、KMS キーのキーポリシーと、外部ユーザーアカウントの IAM ポリシーのアクセス許可が必要です。」）

ローテーションと削除

自動キーローテーション（キー ID は同じまま、中身の鍵が増えていく）



古いマテリアルは残るので、1 や 2 で暗号化したデータもそのまま復号できる。アプリの変更は要らない

削除

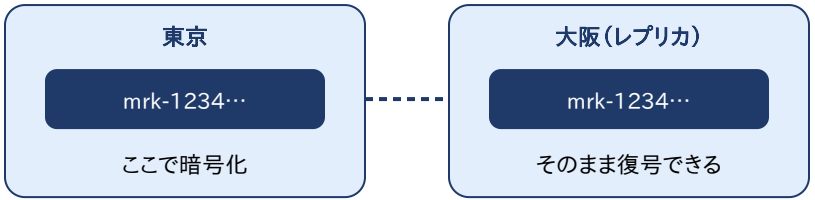


	カスタマーマネージドキー	AWS マネージドキー
自動ローテーション	選んで有効にする。デフォルトの期間は 365 日（期間は変えられる）。オンデマンドでも回せる	毎年自動。止めたり変えたりできない
使わなくなったら	迷ったら**無効化**（戻せる）。削除はそのキーのデータが二度と復号できなくなる	**削除できない**

出典：ローテーション AWS KMS keys（「デフォルトのローテーション期間は 365 日です。」）／AWS KMS key を削除する（「KMS キーを削除すると、その KMS キーで暗号化されたデータを復号できなくなります。」「デフォルトの待機時間は、30 日です。」）

マルチリージョンキーとキーマテリアルのインポート

マルチリージョンキー



同じキーマテリアル・同じキー ID。ポリシーは別々

使う場面：リージョンをまたぐ災害対策・バックアップ、世界に配るアプリ。普通のキーのまま別リージョンに複製したデータは、その先のリージョンのキーで再暗号化が要る。

キーマテリアルのインポート（BYOK）

項目	中身
何をする	マテリアルなしで KMS キーを作り、自分の鍵を取り込む
できること	有効期限を付ける・すぐ消す
責任	キーマテリアルの責任は自分に残る
合う要件	「自社で作った鍵を使う」「鍵をすぐ消せること」

出典：AWS KMS のマルチリージョンキー（「バックアップおよびリカバリアーキテクチャでは、マルチリージョンキーを使用すると、AWS リージョン 停止が発生した場合でも、暗号化されたデータを中断することなく処理できます。」）／キーマテリアルのインポート（「ただし、キーマテリアルを使用せずに KMS キーを作成し、独自のキーマテリアルをその KMS キーにインポートできます。」）

第2章

HSM・証明書・秘密情報

専用の金庫が要るなら CloudHSM。HTTPS の証明書は ACM。パスワードはコードから外して Secrets Manager へ。

KMS と CloudHSM

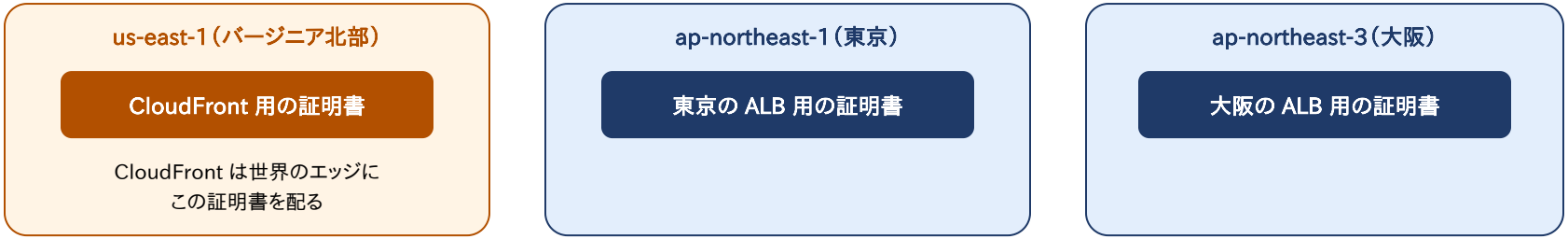
	AWS KMS	AWS CloudHSM
HSM	AWS が運用するマネージドな HSM（FIPS 140-3 レベル 3 で検証）	自分専用・シングルテナントの HSM のクラスター
制御	キーポリシーと IAM。運用は AWS	キー・アルゴリズム・ユーザーを自分で完全に制御。AWS には見えない
AWS サービスとの統合	**S3・EBS・RDS など多数**	直接はない（カスタムキーストア経由で KMS と組み合わせる）
責任	小さい	**大きい（クラスターの冗長化なども考える）**

カスタムキーストア：KMS キーのキーマテリアルを、自分の CloudHSM クラスターで作って保存。暗号の処理はクラスターの HSM の中。KMS の統合と CloudHSM の制御のいいとこ取り。

本番の言い回し：「シングルテナント」「専用の HSM」「キーを AWS にも見せない」→ CloudHSM。「S3 や EBS とかんたんに統合」→ KMS。

出典：とは AWS CloudHSM（「このコントロールのトレードオフは、マネージド型の AWS サービスを使用した場合よりも責任が大きくなることです。」）／AWS CloudHSM キーストア（「カスタムキーストアで KMS キーを使用する際、[暗号化オペレーション]はクラスター内の HSM で実行されます。」）

ACM の証明書はリージョンで決まる



構成は Claude が作った例

同じドメインでも、リージョンごとにリクエスト（またはインポート）する。
リージョン間でコピーはできない

	ACM で発行した証明書	インポートした証明書
料金	追加料金なし	追加料金なし
更新	ELB・CloudFront などに付けていれば、DNS 検証なら自動	自動更新なし。期限を見張って再インポート

出典：とは AWS Certificate Manager（「リージョン間で証明書をコピーすることはできません。」「Amazon CloudFront で ACM 証明書を使用するには、米国東部 (バージニア北部) リージョン の証明書をリクエスト (またはインポート) していることを確認します。」）／証明書のインポート（「インポートした証明書の有効期限をモニタリングし、失効する前に更新する責任はお客様に帰します。」）

Secrets Manager と Parameter Store



パスワードが変わってもアプリの更新は要らない（図は模式図）

	Parameter Store	Secrets Manager
向いているもの	AMI ID・URL などの設定値	DB の認証情報・API キー
暗号化	SecureString で KMS	KMS
ローテーション	なし	自動
料金	標準階層は無料	シークレットごと・API コールごと

AWS のおすすめの置き場所（Secrets Manager のドキュメントより）

AWS の認証情報	暗号化キー	SSH キー	プライベートキーと証明書	DB の認証情報・API キー
IAM（ロール）	KMS	EC2 Instance Connect	ACM	Secrets Manager

出典：とは AWS Secrets Manager（「Secrets Manager で、シークレットの自動ローテーションスケジュールを設定することができます。」）／AWS Systems Manager Parameter Store（比較表・「データベース認証情報、API キー、トークンなどのシークレットの場合は、AWS Secrets Manager をお勧めします。」）

第3章

ストレージと通信の暗号化

S3 は5つの選び方。EBS と RDS は「作るときに暗号化」が基本で、あとからはスナップショット経由。

S3 の暗号化の選び方

方式	キーを管理するのは	特徴	合う要件
SSE-S3	S3	全バケットのデフォルト。2023 年 1 月 5 日から新しいオブジェクトは自動で暗号化。追加費用なし	とくに要件がない
SSE-KMS	KMS（aws/s3 かカスタマーマネージド）	キーの権限で復号できる人を分ける。CloudTrail で監査。KMS の料金がかかる	監査・権限の分離・アカウント間の共有（カスタマーマネージド）
DSSE-KMS	KMS	独立した2つの AES-256 の層	「2層の暗号化」が必要
SSE-C	お客様（リクエストごとに渡す）	S3 はキーを保存しない。キーをなくすとデータも失う。HTTPS 必須。新しいバケットではデフォルトで無効（2026 年 4 月から）	キーを AWS に預けたくないが、暗号化処理は S3 に任せたい
クライアント側	お客様	S3 に送る前に暗号化。S3 は中身を知らない	AWS をふくむ第三者に中身を見せない

S3 バケットキー：SSE-KMS で KMS への呼び出しを減らし、KMS のリクエストコストを最大 99% 削減。「SSE-KMS の KMS の料金が高い」→ これ。

ひっかけ：「SSE-S3 でキーの使用を CloudTrail で監査」はできない。キーの監査が要るなら SSE-KMS。

出典：サーバー側の暗号化によるデータの保護（「Amazon S3 マネージドキーによるサーバー側の暗号化 (SSE-S3) は、Amazon S3 のすべてのバケットでのデフォルトの暗号化設定です。」）／SSE-C（「これは、暗号化キーを紛失した場合、オブジェクトも失われることを意味します。」）／S3 バケットキー／クライアント側の暗号化（「Amazon S3 は、すでに暗号化されているオブジェクトを受け取るだけで、オブジェクトの暗号化または復号には関与しません。」）

転送中の暗号化：HTTPS を強制する

S3：HTTP のリクエストを拒否するバケットポリシー

```
{
  "Effect": "Deny",
  "Principal": "*",
  "Action": "s3:*",
  "Resource": [
    "arn:aws:s3:::example-bucket",
    "arn:aws:s3:::example-bucket/*"
  ],
  "Condition": {
    "Bool": { "aws:SecureTransport": "false" }
  }
}
```

ステートメントは Claude が書いた例（バケット名は例）。HTTPS でないリクエストを明示的に拒否する。

場所	転送中の暗号化
S3	バケットポリシーで `aws:SecureTransport` を使い HTTPS だけを許可
ALB・CloudFront	ACM の証明書で HTTPS のリスナー
RDS	SSL/TLS で接続。サーバー証明書を検証すれば相手も確かめられる
EBS	暗号化ボリュームなら、ボリュームとインスタンスの間も暗号化

保存時と混同しない：デフォルトの暗号化を SSE-KMS にしても、HTTP の接続は止まらない。

出典：Amazon S3 のセキュリティのベストプラクティス（「HTTPS (TLS) を使用すると、潜在的な攻撃者が中間者攻撃または同様の攻撃を使用してネットワークトラフィックを盗聴または操作することを防止できます。」）／SSL/TLS を使用した接続の暗号化（「SSL/TLS 接続は、クライアントと DB インスタンスまたはクラスターの間を移動するデータを暗号化することによって、1 つのセキュリティ層を提供します。」）

EBS の暗号化

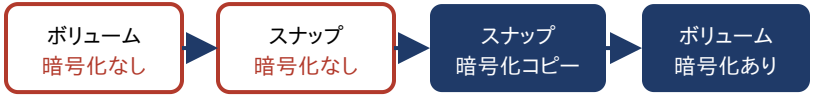
暗号化したボリュームで暗号化されるもの

1	ボリューム内の保存データ
2	ボリュームとインスタンスの間で移動するデータ
3	ボリュームから作ったスナップショット
4	そのスナップショットから作ったボリューム

デフォルトでの EBS 暗号化

リージョンごとの設定。有効にすると、そのリージョンで新しく作るボリュームとスナップショットは必ず暗号化され、個別に無効にはできない。既存のものには影響しない。

暗号化していないボリュームを暗号化する



スナップショットを取り → 暗号化してコピー →
新しいボリュームを作ってインスタンスに付け替える

（暗号化なしのスナップショットから、暗号化した
ボリュームを直接作ることもできる。図は模式図）

> **その場で暗号化はできない：**既存のボリュームの設定を変えて暗号化する方法はない。

出典：Amazon EBS 暗号化の仕組み（「暗号化されていないスナップショットから暗号化されたボリュームを作成する場合、Amazon EC2 は AWS KMS と連携して、次のように EBS ボリュームを暗号化および復号化します。」）／デフォルトで Amazon EBS の暗号化を有効化（「デフォルトでの暗号化はリージョン固有の設定です。」）

RDS の暗号化

できる・できない	答え
作るときに暗号化する	できる
作ったあとで、その場で暗号化する	できない
暗号化を外す	できない
暗号化していない DB のリードレプリカだけ暗号化	できない
暗号化していないスナップショットを暗号化してコピー	できる
暗号化スナップショットを別リージョンへコピー	できる（先のリージョンの KMS キーを指定）

暗号化した DB では、ストレージ・ログ・自動バックアップ・リードレプリカ・スナップショットがすべて暗号化される。

暗号化していない DB を暗号化する手順

1 スナップショットを取る
暗号化なしのスナップショット

2 コピーするときに暗号化
KMS キーを指定

3 暗号化スナップショットから復元
新しい暗号化 DB ができる

4 アプリの接続先を切り替える
ブルー/グリーンデプロイでも暗号化できる

出典：Amazon RDS リソースの暗号化（「Amazon RDS DB インスタンスは、DB インスタンスの作成時にのみ暗号化できます。」「暗号化された DB インスタンスの暗号化をオフにすることはできません。」「保管中に暗号化されるデータには、DB インスタンス、ログ、自動バックアップ、リードレプリカ、スナップショットの基本的なストレージが含まれます。」）

選び分け:この要件ならこれ

要件	答え
暗号化キーの権限を自分で決め、使用を監査する	KMS のカスタマーマネージドキー
リージョンをまたいで、再暗号化せずに復号する	マルチリージョンキー
シングルテナントの HSM でキーを完全に自社管理	CloudHSM
CloudFront に独自ドメインの HTTPS	ACM の証明書(us-east-1)
DB のパスワードをコードから外し、自動で変える	Secrets Manager
設定値を安く保存(ローテーション不要)	Parameter Store
SSE-KMS の KMS の料金を下げる	S3 バケットキー
S3 に HTTPS でしかアクセスさせない	バケットポリシーで aws:SecureTransport
リージョンで今後作る EBS をすべて暗号化	デフォルトでの EBS 暗号化
暗号化していない RDS を暗号化	スナップショット → 暗号化コピー → 復元

出典:このPDFの各ページの資料

まとめ

KMS
3種類のキー。キーポリシーは必ず1つ。データキーで封をするエンベロープ暗号化。削除は 7〜30 日待ってから

HSM と証明書
CloudHSM＝専用・自分で管理。ACM＝無料・自動更新。CloudFront 用は us-east-1

秘密情報
Secrets Manager＝自動ローテーション。Parameter Store＝設定値・標準は無料

保存時と転送中
S3 は5方式＋バケットキー。EBS・RDS はあとからはスナップショット経由。HTTPS は SecureTransport

ひっかけ	正しくは
AWS マネージドキーのポリシーを変える	変えられない
ローテーションで古いデータが読めなくなる	そのまま読める
ACM の証明書をリージョン間でコピー	できない
インポートした証明書も自動更新	されない
Parameter Store で自動ローテーション	ない
RDS をその場で暗号化	できない

> 次の #05 では、CloudTrail・Config・GuardDuty・Macie などのログ・監査と脅威の検出を学ぶ。

出典：このPDFの各ページの資料